



QUANT LAB USA INC

MITRE ATT&CK; Maturity Self-Assessment v2 (2026)

The expanded 2026 edition of our MITRE ATT&CK; maturity instrument. 40 self-assessment questions across all 14 Enterprise tactics, with identity-tier and cloud-tier sub-techniques from the 2025 and 2026 matrix updates, four-tier scoring, and a board-ready summary template.

Published 2026 - Free founder and operator resource
quantlabusa.dev/resources

Table of Contents

- Section 1 - Reconnaissance and Resource Development
- Section 2 - Initial Access
- Section 3 - Execution
- Section 4 - Identity and Credential Access
- Section 5 - Cloud and Container
- Section 6 - Defense Evasion and Persistence
- Section 7 - Discovery, Lateral Movement, and Collection
- Section 8 - Exfiltration, Impact, and Board-Ready Summary
- Section 9 - Scoring Rubric and 30-60-90 Remediation Plan

About this document

This document is a free resource published by QUANT LAB USA INC, a Georgia-incorporated technology company building custom business software, SaaS platforms, and security engineering for mid-market and SMB operators. It is informational only and does not constitute legal, tax, accounting, or financial advice. Always verify decisions with a qualified licensed professional in your jurisdiction.

Section 1

Reconnaissance and Resource Development

External-facing posture is the front of the kill chain. Attackers spend meaningful time on reconnaissance before any payload lands on your network. The controls below mitigate the reconnaissance and resource-development tactics that produce target-enumeration before attempted access.

Q1. External Attack Surface Monitoring

Do you have a documented, current inventory of internet-facing assets - domain names, IP ranges, exposed services, third-party SaaS endpoints reachable from public internet? Yes / Partial / No.

Q2. Leaked Credential Detection

Do you continuously monitor credential leak sources (HaveIBeenPwned, commercial breach feeds, Pastebin-style sites) for credentials associated with your domain(s)? Yes / Partial / No.

Q3. Brand and Typosquat Monitoring

Do you monitor for typosquat domains, brand-impersonation domains, and certain TLS certificate issuance patterns that signal active phishing infrastructure setup? Yes / Partial / No.

Q4. Public Code and Configuration Exposure

Do you scan for accidentally-published secrets, API keys, and infrastructure configuration in your public GitHub, public S3 buckets, and similar surfaces? Yes / Partial / No.

Why this matters: The reconnaissance phase produces the target list for the active phase. Most teams under-instrument here because the indicators are external and the controls are mostly automated. Coverage in this section is the single highest leverage area for catching attempted compromises early.

Section 2

Initial Access

Initial access is the moment an attacker first establishes a foothold in your environment. The MITRE Enterprise matrix lists multiple sub-techniques; this section scores the controls against the five most common in the 25-to-500-employee ransomware target profile.

Q5. Phishing Defense

Do you have email security gateway filtering, URL rewriting, attachment sandboxing, and user-reported-phishing analysis workflows? Yes / Partial / No.

Q6. Valid Account Abuse Defense

Do you enforce strong MFA on all SaaS and infrastructure logins, with phishing-resistant MFA (FIDO2 or hardware token) for privileged accounts? Yes / Partial / No.

Q7. Exploit Public Application

Do you patch internet-facing applications within 14 days of vendor patch release? Do you have WAF protection for custom-developed applications? Yes / Partial / No.

Q8. Supply Chain Compromise

Do you have SBOM (Software Bill of Materials) for production applications, dependency vulnerability scanning in CI, and a process for responding to upstream package compromises? Yes / Partial / No.

Q9. Trusted Relationship Abuse

Do you maintain role-based access control on third-party access (vendors, contractors, MSPs) and review/revoke quarterly? Yes / Partial / No.

Section 3

Execution

Execution is the running of attacker-controlled code in your environment. The 2026 matrix expanded coverage of container and cloud workload execution patterns.

Q10. Command-Line and Scripting Detection

Do you have EDR coverage detecting suspicious PowerShell, cmd.exe, bash, Python, and macro execution patterns? Yes / Partial / No.

Q11. Container Execution

Do you have container runtime security detecting unauthorized exec into containers, suspicious process trees inside containers, and container-escape attempts? Yes / Partial / No.

Q12. Cloud Workload Execution

Do you have CSPM/CWPP coverage detecting unauthorized lambda invocations, suspicious EC2 user-data execution, and cloud-shell session abuse? Yes / Partial / No.

Section 4

Identity and Credential Access

The identity layer is where the modern ransomware kill chain operates. The 2025 matrix update added significant identity-tier coverage; v2 of this assessment weights identity heavily for that reason.

Q13. Token Theft Detection

Do you detect anomalous OAuth token issuance, refresh token reuse from different IP/UA, and SAML token replay? Yes / Partial / No.

Q14. MFA Bypass Detection

Do you detect MFA push fatigue patterns, SIM swap indicators, MFA fallback abuse, and conditional access policy bypass attempts? Yes / Partial / No.

Q15. OAuth Application Abuse

Do you review and approve OAuth application installations into your tenant? Do you detect anomalous OAuth grant patterns from end users? Yes / Partial / No.

Q16. Password Spraying Defense

Do you have rate limiting on authentication endpoints, lockout policies calibrated against spray patterns, and alerting on cross-account low-volume auth failures? Yes / Partial / No.

Q17. Credential Stuffing Defense

Do you check authentication attempts against known-breached credential databases at sign-in time? Yes / Partial / No.

Q18. Privileged Account Hygiene

Do you use Privileged Identity Management (PIM/PAM) with just-in-time elevation for admin roles? Yes / Partial / No.

Section 5

Cloud and Container

Cloud-tier and container-tier sub-techniques were expanded in the 2026 matrix. This section scores controls against cloud account compromise, container escape, and cloud storage exfiltration patterns common in modern ransomware kill chains.

Q19. Cloud Account Compromise Detection

Do you detect cloud root account login, unusual IAM role assumption, and anomalous API call patterns from compromised cloud credentials? Yes / Partial / No.

Q20. Container Escape Defense

Do you enforce read-only root filesystems, drop unnecessary capabilities, and run containers with non-root users by default? Yes / Partial / No.

Q21. Kubernetes RBAC

Do you have least-privilege RBAC configured on your Kubernetes clusters, with service-account audit and rotation? Yes / Partial / No.

Q22. Cloud Storage Exfiltration

Do you detect anomalous data egress from S3, Azure Blob, or GCS buckets, including patterns indicating data staging for exfiltration? Yes / Partial / No.

Q23. Secrets Management

Do you use a centralized secrets vault for all production credentials, with rotation policies and access logging? Yes / Partial / No.

Section 6

Defense Evasion and Persistence

Once initial access is achieved, attackers establish persistence and evade detection. The controls in this section detect the dwell-time tactics common in the 30-to-90-day pre-encryption phase of modern ransomware operations.

Q24. Process Injection Detection

Do you have EDR detecting common process injection techniques (DLL injection, process hollowing, APC injection)? Yes / Partial / No.

Q25. Scheduled Task and Service Persistence

Do you detect newly-created scheduled tasks, services, and startup items on production workstations and servers? Yes / Partial / No.

Q26. Registry and File-Based Persistence

Do you monitor for changes to known persistence registry keys and startup directories? Yes / Partial / No.

Q27. Living-Off-the-Land Detection

Do you detect abuse of legitimate Windows binaries (PowerShell, WMI, PsExec, regsvr32) for attacker tooling? Yes / Partial / No.

Q28. Disable Defenses

Do you detect and alert on EDR tampering, security log clearing, and Windows Defender disable attempts? Yes / Partial / No.

Section 7

Discovery, Lateral Movement, and Collection

Attacker dwell time is spent on internal reconnaissance, lateral movement, and data collection. This section covers the controls that catch this activity and shorten dwell time.

Q29. Network Share Enumeration

Do you detect unusual network share access patterns - particularly broad enumeration of file shares by single accounts? Yes / Partial / No.

Q30. Account Discovery

Do you detect Active Directory enumeration (BloodHound, ADRecon, Get-NetUser style queries) from non-admin accounts? Yes / Partial / No.

Q31. Remote Service Abuse

Do you detect RDP, SMB, WinRM, and SSH access patterns inconsistent with normal admin or user workflow? Yes / Partial / No.

Q32. Pass-the-Hash and Kerberoasting

Do you detect Kerberoasting, AS-REP roasting, and pass-the-hash patterns in your authentication logs? Yes / Partial / No.

Q33. Data Staging

Do you detect anomalous data aggregation, archive creation, and staging-directory patterns that precede exfiltration? Yes / Partial / No.

Q34. Internal Email Collection

Do you detect anomalous email forwarding rule creation, mass mailbox export, and unusual eDiscovery activity? Yes / Partial / No.

Section 8

Exfiltration, Impact, and Board-Ready Summary

The final phase of the kill chain. Controls here mitigate exfiltration of stolen data, encryption-for-ransom impact, and operational disruption.

Q35. Exfiltration over Web Service

Do you detect unusual outbound traffic to file-sharing services (Dropbox, Mega, Anonfile-style) from non-standard accounts? Yes / Partial / No.

Q36. Exfiltration over C2 Channel

Do you have egress monitoring detecting DNS exfiltration, anomalous encrypted traffic patterns, and beaconing to known C2 infrastructure? Yes / Partial / No.

Q37. Backup Defense

Are your backups immutable, isolated from production credentials, and tested via documented quarterly restore drills? Yes / Partial / No.

Q38. Ransomware Detection

Do you have detection for mass file modification, shadow copy deletion, and known ransomware behaviors? Yes / Partial / No.

Q39. Incident Response Plan

Do you have a documented IR plan that has been tabletop-tested in the last 12 months and includes ransomware-specific decision branches? Yes / Partial / No.

Q40. Recovery Time Objective

Can you document a defensible RTO and RPO for your top three business-critical systems, validated through restoration test? Yes / Partial / No.

Board-Ready Summary Template

Sample summary for cyber insurance application: 'In Q[N] [YEAR], [ORGANIZATION] completed an internal MITRE ATT&CK Enterprise maturity self-assessment across the 14 tactics and 40 sub-control areas. Overall coverage is [XX]% with a maturity tier of [REACTIVE / DEVELOPING / DEFENDED / PROACTIVE]. The highest-coverage tactics are [TACTICS]; the lowest-coverage tactics with documented 30-60-90 remediation plans are [TACTICS]. Assessment is reviewed annually and findings are reported to the [BOARD / SECURITY COMMITTEE].'

Section 9

Scoring Rubric and 30-60-90 Remediation Plan

Each question is scored as 2 (yes), 1 (partial), or 0 (no). Total raw score is out of 80. Coverage percentage rolls up to the four-tier label below.

Coverage %	Tier	Definition
0-25%	Reactive	Mostly responding to incidents after the fact.
26-55%	Developing	Foundational controls in place; gaps in detection depth.
56-80%	Defended	Multi-layer controls; documented response capability.
81-100%	Proactive	Detection, hunting, and continuous improvement maturity.

30-60-90 Remediation Plan Template

Pick your three lowest-scoring tactic groups and assign each to a 30/60/90-day remediation timeline based on cost and dependencies.

- **30 days (no-budget items):** Configuration changes, policy updates, documentation, free-tier tooling, and quick wins requiring no procurement.
- **60 days (modest tooling):** Purchase or expansion of existing tooling, vendor onboarding, training, and one-time professional services engagements.
- **90 days (structural):** Architectural changes, capital budget items, compliance program changes, and the budget-cycle conversation to fund the rest.

Contact & Next Steps

Ready to act on what is in this document?

If the contents of this PDF prompted a question you want a second set of eyes on, or if you are ready to scope a related engagement, we run a 20-minute discovery call at no cost. The conversation is structured: 5 minutes on your context, 10 minutes on the specific decision in front of you, 5 minutes on what good next steps look like.

- Book a 20-minute scoping call: quantlabusa.dev/contact
- Learn about our MITRE ATT&CK; Assessment practice: quantlabusa.dev/services/mitre-attack-assessment
- Browse our full resources library: quantlabusa.dev/resources
- Read recent case studies: quantlabusa.dev/work
- Pricing and discovery sprint options: quantlabusa.dev/pricing

Who is QUANT LAB USA?

QUANT LAB USA INC is a Georgia-incorporated technology consultancy. We build custom business software, SaaS platforms, payments and licensing infrastructure, and security engineering for mid-market and SMB operators. We are deliberately structured as a small, senior-engineering-led practice - the people on your scoping call are the people who build the system. If a custom build is on the table, we typically begin with a paid discovery sprint that produces wireframes, a database schema, and a phased build estimate.

QUANT LAB USA INC

Georgia C-Corporation - SOS #26086454 - EIN 42-2039870

Web: quantlabusa.dev - Email: hello@quantlabusa.dev

Resources library: quantlabusa.dev/resources